

OWASP Top 10

Security Logging and Alerting Failures

BIG school

BIGSEIO

GENERAMOS
NEGOCIO

Security Logging and Alerting Failures

Índice

- Introducción
- ¿Qué significa esta vulnerabilidad?
- ¿Por qué ocurre esta vulnerabilidad?
- Ejemplos reales y típicos
- ¿Qué puede hacer un atacante si explota esto?
- ¿Cómo detectarlo?
- ¿Cómo prevenirlo?
- ¿Cómo mitigar si ya estás afectado?
- Checklist rápido
- Conclusiones



Security Logging and Alerting Failures

BIG school

Introducción

- **Logging y monitoreo: el sistema nervioso de tu aplicación**
- **Sin visibilidad, los ataques pasan desapercibidos**
- **No es solo "guardar logs": es registrar, analizar y alertar**
- **Objetivo: detectar, responder y aprender de incidentes en tiempo real**

¿Qué significa esta vulnerabilidad?

- Falta de registro de eventos críticos de seguridad
- Monitoreo ausente o sin análisis en tiempo real
- Alertas inexistentes, genéricas o ignoradas
- Sin trazabilidad: imposible investigar o cumplir normativas

¿Por qué ocurre esta vulnerabilidad?

- Logging como afterthought: solo para debug, no para seguridad
- Logs sin contexto: "Error 500" sin usuario, IP o acción
- Almacenamiento local, volátil y modificable
- Ausencia de alertas automatizadas o umbrales accionables
- Cultura reactiva: "si no hay error, no hay problema"

Ejemplos reales y típicos

- Fuerza bruta en login sin registro ni alerta de intentos fallidos
- Logs genéricos sin user_id, trace_id o timestamp preciso
- Rotación automática: logs borrados a las 24h sin política de retención
- Logs locales en texto plano: accesibles y modificables por atacantes
- Alert fatigue: miles de alertas no priorizadas que el equipo ignora

¿Qué puede hacer un atacante si explota esto?

- Moverse lateralmente y escalar privilegios sin activar alarmas
- Exfiltrar datos progresivamente para evadir umbrales de detección
- Borrar o alterar logs para ocultar evidencia de la intrusión
- Instalar backdoors o modificar configs con persistencia encubierta
- Impacto regulatorio: incumplimiento de GDPR, PCI-DSS, ISO 27001

¿Cómo detectarlo?

- **Code review:** verificar que eventos críticos se registran con contexto
- **Pentesting:** ejecutar ataques controlados y validar logs/alertas
- **Producción:** auditar retención, permisos e integridad de logs
- **Señales:** logs locales sin centralización, alertas ignoradas, ausencia de trace_id

¿Cómo prevenirlo?

1. **Security by Design:** definir qué registrar antes de codificar
2. **Formato estructurado (JSON)** con `correlation_id`, usuario, IP, acción
3. **Centralización en SIEM/cloud** con inmutabilidad (WORM, firmas)
4. **Alertas inteligentes:** umbrales basados en riesgo + integración con Slack/PagerDuty
5. **Runbooks de respuesta:** playbook claro para cada tipo de alerta
6. **Retención alineada a normativas** + backups cifrados y acceso restringido

¿Cómo mitigar si ya estás afectado?

1. Identificar brechas: mapear eventos críticos sin registro o contexto
2. Implementar logging urgente: middleware para auth, accesos, errores
3. Centralizar y proteger: redirigir logs a SIEM con permisos estrictos
4. Activar alertas básicas: fallos de login, cambios de permisos, picos de errores
5. Auditar integridad: verificar que logs existentes no fueron alterados
6. Establecer retención y automatizar validación en CI/CD

Checklist rápido

- ✓ ¿Eventos críticos (auth, permisos, configs) se registran con contexto completo?
- ✓ ¿Logs en formato estructurado (JSON) con correlation_id/trace_id?
- ✓ ¿Centralizados en SIEM/cloud con acceso restringido e inmutabilidad?
- ✓ ¿Alertas automatizadas y priorizadas para eventos anómalos?
- ✓ ¿Runbooks claros para cada tipo de alerta?
- ✓ ¿Política de retención cumple con normativas aplicables?
- ✓ ¿Se validan logs y alertas en pruebas de seguridad o pentests?

Conclusiones

- No puedes proteger lo que no ves: logging es visibilidad, no burocracia
- Contexto + centralización + alertas accionables = detección temprana
- Inmutabilidad y retención son clave para forense y cumplimiento
- Como desarrollador: añadir contexto, estructurar logs y validar alertas
- Pregunta clave: "¿Sabría en 5 minutos si alguien abusa de esto?"



¡MUCHAS GRACIAS!

BIG school

BIGSEIO

**GENERAMOS
NEGOCIO**